Evidence-based Policy Group Assessment

From log evidence to security policy

Enterprise Cyber Security

The Assessment

Worth 20% of your course grade

- Work in a **group of 5–6** to find evidence of an attack in server logs, then build a risk assessment and a **policy**.
- The report must not exceed **6 pages**. Page counts per part are guidance only.
- The full specification is on the **course Moodle page**.



The Scenario
Solstice Continental

- A large fictional retailer. Customer orders, contact details and payment information sit in the `orders` database.
- **Customer data** is the principal asset. The organisation is legally responsible for protecting it.
- Third-party contractors have remote access to its systems.
- Your logs are `auth.log` (logins and `sudo`) and `daemon.log` (services, cron and the nightly backup).

The Scenario

Management's three questions

1. What happened?
2. What risks does this expose for the customer data?
3. What should the organisation do about the most serious of them?

Your logs are unique to your group. Addresses, account names, times and counts differ between groups, so every value you report must come from your own logs.

Ground Rules

Keep evidence and interpretation distinct

- Every quantitative statement about your logs comes from **your script**.
- Every individual entry you rely on is **quoted directly** from the logs.
- Claims about the wider threat landscape need a **cited source**.
- Classing activity as normal, suspicious or serious is your group's judgement. Your report must make the reasoning explicit.

The Four Parts

Part 1. Analysis

About 1.5 pages. Establish what happened

- Find **evidence of each attack**: which techniques from lectures appear in your logs, and the log lines that show each one.
- Find **evidence of the chain**: how the attacks connect, in order, from the first attempt to gain access through to the action against customer data.
- Run the script from the plenary on your two logs.
- State the rules you use to classify events, and note any limitations or gaps in the evidence.

Part 1. Analysis

Required outputs

Output	What it must show
Source summary	Failed and successful logins for each source address, marked internal or external, as written by the script
Evidence lines	Every line that mentions the attacker's address or the compromised account, in both logs. Quote the lines you rely on
Table 1, Incident facts	Attacker address, compromised account, and the time and log line for each key event, from first access attempt to the action against customer data
Table 2, Attack chain	Every stage in order, drawing on both logs, with the time, the quoted log line and what it shows

Part 2. Risk Assessment

About 2 pages. Turn the evidence into ranked risks

Step	What you do
Step 1	Identify **at least five risks**. For each, state the weakness or missing control, what could happen to the customer data, and the log evidence that shows it
Step 2	Devise your own **likelihood and impact scales** built around the assets. Rate each risk and justify every rating
Step 3	Present a risk matrix and a ranked table. Select the **three highest-ranked risks** for Parts 3 and 4. Explain any ties, and why the risks ranked fourth and below were not selected

Part 2. Risk Assessment

Scales and sources

- **Likelihood** is the chance the weakness is exploited again within a year, with the controls as they stand. Each level must be clear enough that another reader could place a risk in it.
- **Impact** is the consequence for your assets, such as data exposed or lost, time the business could not use it, and legal, financial and reputational effects. Generic impact levels earn little credit.
- Combine the two ratings into a score, for example by multiplying them. Explain why your scales suit this organisation.
- Cite at least **four external sources**, including one **peer-reviewed** source. Use academic, industry or government reports, or news of real incidents.
- Say whether each rating rests on your logs, an external source, or both.

Part 3. Policy

About 1 page. Write it as Solstice Continental would publish it

- Include a **purpose**, a **scope** (who and what it applies to) and a set of clear policy statements.
- Every statement must **name the risk** from Part 2 that it addresses.
- Each of your three selected risks must be covered by at least one statement.
- The policy should be proportionate: strong enough to reduce the risk, and not so demanding that it cannot be followed.
- The policy must be **no longer than one page**.

Part 4. Implementation and Evaluation

About 1.5 pages. Cover all three risks

- **Implementation plan**: what would change (technical, operational or cultural), who is responsible, in what order and over what timescale.
- **Evaluation metrics**: what each one measures, how and how often it is collected, and what result counts as success. Explain why each is appropriate.
- **Residual risk**: what would remain once the policy is in place.
- Use metrics the organisation could realistically collect.

Rules and Submission

Use of AI

Classification: BROAD USE

- **Permitted**: use AI across the process, for example to understand the log format, to explain or debug `analysis.py`, to find sources, and to help with structure and wording.
- **Prohibited**: the classification rules and conclusions in Part 1, the scales, ratings, ranking and selection in Part 2, and the policy statements, metrics and residual risk judgements in Parts 3 and 4 must be your group's own work.
- **AI output is not evidence**. Every number comes from your script and every quoted line from your logs.
- **One joint declaration per group** on the course Moodle page, agreed before any group work begins. **Due Friday 16 October 2026.**
- Acknowledge all AI use at the end of the report, after the references.

Group Work

Your responsibilities

- Find your group on the course Moodle page, contact each member and schedule your own meetings outside class.
- Attend the **Wednesday plenary in person** and sit together as a group.
- Complete the group work wellbeing survey on Moodle by **Friday 30 October 2026**.
- All communication between group members must be in English.
- If a member is hard to contact or not engaging, tell the course coordinator **as soon as possible**. Do not wait for the next plenary.

Group Work

Workload Record and problems

- The one-page **Workload Record** is mandatory. Any form is acceptable, and *All members contributed equally* is allowed.
- Record your meetings, Wednesday check-ins and agreed solutions. A report without a Workload Record takes the 2-band penalty.

If your group has a problem

1. Meet as a group, settle a solution and note it in the Workload Record.
2. If the group cannot settle, raise it with the course coordinator.
3. If a solution is not working, meet again, document it and raise it with the course coordinator.

Individual Grades

How they are set

- The report receives a **group mark**.
- The Workload Record and each member's private Personal Assessment of Contribution inform their individual grade.
- A Personal Assessment of Contribution **never sets a grade directly**. Any difference from the group mark must be supported by the Workload Record.
- If these sources do not show unequal contribution, every member receives the group mark.

Submission

One zip file via Moodle

- One nominated member submits on behalf of the group. The others check the submission link.
- Name the zip with every group member's matriculation number, separated by underscores, ending in `_submission.zip`.
- Contents: `report.pdf`, `analysis.py`, `source_summary.csv` and `evidence_*.txt`.
- `python3 analysis.py` run on a `logs/` folder must reproduce the summary and evidence files.

Submission

Before you submit

- Put a note at the top of `analysis.py` naming your group and the `INTERNAL_PREFIX` and `KEYS` values.
- The report is a PDF with a 12-point font and 1-inch margins. Label the team name and members on the cover page.
- Each member's Personal Assessment of Contribution is submitted separately. Do not put it in the zip.
- Non-adherence to the submission instructions carries a 2-band penalty.

Marking Scheme

Six criteria, graded A to G

Criterion	Weight
Analysis	25%
Risk Assessment	30%
Policy	20%
Implementation and Evaluation	15%
Written Quality	5%
Team Performance	5%

Grade labels follow Schedule A of the University's Code of Assessment.

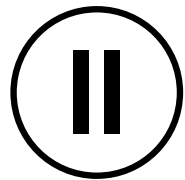
Non-adherence to the submission instructions carries a 2-band penalty.

Timetable

Key dates

Milestone	Date
Specification released	Friday 9 October 2026
Group AI declaration	**Friday 16 October 2026**
Group wellbeing survey completed	Friday 30 October 2026
Assessment week, before the deadline	To be confirmed
Final report submission, 16:30	**Wednesday 18 November 2026**

What will your group agree before Friday?



Evidence-based Policy Group Assessment

From log evidence to security policy

Enterprise Cyber Security